Security incident report

Section 1: Identify the network protocol involved in the incident
Based on the analysis of the tcpdump logs, the network protocols involved in the incidents are **DNS**, **TCP**, **HTTP**. The client sends a **DNS** request to the DNS Server to find the server address of the website. Then, the DNS Server responds with the IP of 203.0.113.22 which is the IP Address of the website yummyrecipesforme.com The client establishes a connection with the web server using the **TCP** Protocol. The log shows the three-way handshake which are the SYN [S], SYN-ACK[S.], ACK[.] flags. After the TCP connection, the client sends an **HTTP GET** request to retrieve the webpage over the port 80.

Section 2: Document the incident
Several customers reported to the helpdesk that when they visited **yummyrecipesforme.com**, the website prompted them to download a file in order to access free recipes. After running the file, customers reported that their browsers were redirected to another website and that their computers began operating more slowly. After receiving the reports, the cybersecurity team began investigating the issue. The website owner attempted to log in to the administrative panel but was unable to access the account. The hosting provider was then contacted for assistance. To investigate the behavior of the website, a sandbox testing environment was created. A network protocol analyzer, tcpdump, was used to capture network traffic while accessing the website. The logs showed that the browser first sent a DNS request to retrieve the IP address for **yummyrecipesforme.com**, which returned the IP address **203.0.113.22**. After

the DNS response, the browser established a TCP connection and sent an HTTP request to load the webpage.

During testing, the webpage prompted the download of an executable file. After the file was executed, the browser initiated another DNS request for **greatrecipesforme.com**, which resolved to the IP address **192.0.2.17**. The browser then sent an HTTP request to this new website, confirming that the user was redirected to a different domain.

Further investigation of the website's source code revealed that unauthorized JavaScript code had been added to the webpage. The code prompted users to download an executable file that contained a script designed to redirect visitors from **yummyrecipesforme.com** to **greatrecipesforme.com**.

A senior cybersecurity analyst confirmed that the web server had been compromised through a **brute force attack** on the administrative account. The attacker repeatedly attempted login attempts using known default passwords until the correct password was guessed. Because the administrative account was still using the default password and there were no controls in place to limit repeated login attempts, the attacker was able to gain access to the admin panel, modify the website source code, and change the administrator password.

Evidence for this investigation was gathered from **customer reports, sandbox testing results, captured network traffic logs using tcpdump, and analysis of the compromised website source code**.

Section 3: Recommend one remediation for brute force attacks
I recommend the use of **account lockout policy** for administrative account to prevent similar incidents in the future. This control limits the number of failed login attempts allowed within a certain period of time. Implementing an account lockout policy would prevent attackers from repeatedly attempting different passwords to gain unauthorized access to the administrative panel. This control would significantly reduce the effectiveness of brute force attacks and help protect administrative accounts from unauthorized access. In addition, the organization should enforce **strong password policies** that require administrators to create complex passwords instead of using default credentials. Implementing **multi-factor authentication (MFA)** would further

strengthen security by requiring an additional verification factor before access to the administrative panel is granted.